

Informe de Seguridad - OWASP ZAP

Version 1 - Post-Remediacion | Proxy: Nginx/Caddy con cabeceras de seguridad

Informacion del Escaneo

Objetivo:	http://localhost:8080 (via Caddy reverse proxy)
Herramienta:	OWASP ZAP 2.16.1
Tipo de escaneo:	Quick Scan (Spider + Active Scan)
Fecha:	17/04/2026
Proyecto:	Dashboard ETalent - ESPOCH
Responsable:	Jefferson Jordan
Version:	v1 - Post-Remediacion

Resumen de Alertas

Nivel de Riesgo	N° de Alertas
Alto	0
Medio	0
Bajo	0
Informativo	2

Remediaciones Aplicadas

[MEDIO]	Cabecera Content Security Policy (CSP)
ID ZAP:	10038
Estado:	RESUELTO
Fix aplicado:	Agregado en deploy/nginx.conf y deploy/Caddyfile: Content-Security-Policy: default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval' https://cdn.plot.ly; connect-src 'self' ws: wss; ...
Artefacto:	deploy/nginx.conf deploy/Caddyfile

[BAJO]	Divulgacion de Marcas de Tiempo (Unix Timestamp)
ID ZAP:	10096
Estado:	RESUELTO
Fix aplicado:	Cabeceras de timestamp eliminadas en el proxy: proxy_hide_header X-Runtime; (Nginx) -X-Runtime, -X-Timestamp, -X-Response-Time (Caddy)
Artefacto:	deploy/nginx.conf deploy/Caddyfile

[BAJO]	Filtracion de version en cabecera 'Server'
ID ZAP:	10036
Estado:	RESUELTO
Fix aplicado:	Version suprimida y cabecera reemplazada:

Informe de Seguridad - OWASP ZAP

	server_tokens off; add_header Server 'ETalent-Dashboard'; (Nginx) -Server Server ETalent-Dashboard (Caddy)
Artefacto:	deploy/nginx.conf deploy/Caddyfile

[BAJO]	Falta encabezado X-Content-Type-Options
ID ZAP:	10021
Estado:	RESUELTO
Fix aplicado:	Cabecera agregada en proxy: add_header X-Content-Type-Options 'nosniff' always; (Nginx) X-Content-Type-Options nosniff (Caddy)
Artefacto:	deploy/nginx.conf deploy/Caddyfile

Alertas Informativas (no requieren accion)

[INFO]	Aplicacion Web Moderna (SPA detectada)
ID ZAP:	10109
Descripcion:	ZAP detecto una SPA React/Streamlit. El spider tradicional tiene cobertura limitada. No es una vulnerabilidad.
Nota:	Usar spider AJAX de ZAP en escaneos futuros para mayor cobertura.

[INFO]	Comentarios sospechosos en JavaScript
ID ZAP:	10027
Descripcion:	Comentarios TODO/FIXME en JS generados por Streamlit/React. No representan vulnerabilidad directa.
Nota:	Se resuelve automaticamente al desplegar en produccion (minificacion).

Conclusiones - Version 1 Post-Remediacion

Las 4 alertas accionables identificadas en el escaneo inicial (1 media, 3 bajas) han sido resueltas mediante la adicion de configuraciones de proxy inverso (deploy/nginx.conf para produccion ESPOCH y deploy/Caddyfile para validacion local en Windows).

El escaneo realizado a traves del proxy en http://localhost:8080 no detecta ninguna alerta accionable. Solo permanecen 2 alertas de nivel informativo relacionadas con la naturaleza SPA de la aplicacion y comentarios de desarrollo, ambas fuera del alcance de remediacion a nivel de cabeceras HTTP.

El dashboard ETalent Version 1 esta listo para su despliegue en infraestructura ESPOCH utilizando la configuracion Nginx proporcionada.